

מודול 16 — כתיבת דוח ותיעוד — תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1.  תרגול — מודול 16: כתיבת דוח ותיעוד

חלק א' — שאלות תרגול

Q1. למה אומרים ש"הדוח הוא המוצר" של בדיקת חדירה?

Q2. מהם Scope ו-RoE, ומתי מגדירים אותם?

Q3. מהם שני הקהלים של הדוח, ואיזה חלק מיועד לכל אחד?

Q4. מה חייב לכלול ממצא מקצועי?

Q5. מה עושה CVSS, ומהו טווח הציונים ל-Critical?

Q6. מדוע מדרגים לפי "סיכון עסקי" ולא רק ציון טכני?

Q7. למה מתעדים ממצאים בזמן אמת ולא בסוף?

Q8. מהי ההמלצה לכמות הזמן שיש להקדיש לתיעוד ולדוח?

תשובות

- הלקוח לא רואה את הפריצה — רק את הדוח; הוא המסמך שמתרגם ממצאים לערך (סיכון, תיקון, ציות) ומצדיק את התשלום.
- Scope = מה מותר לבדוק; RoE = איך ומתי. מגדירים בכתב לפני הבדיקה (Pre-Engagement).
- הנהלה (Executive Summary — שפה עסקית) וצוות IT (ממצאים מפורטים — איך לתקן).
- תיאור, השפעה (Impact), PoC (צעדים+צילומים), המלצת תיקון, והפניות (CVE/OWASP/CWE).
- מערכת ציון 0-10 לחומרת חולשה; Critical = 9.0-10.0.
- אותה חולשה טכנית עשויה להיות דחופה יותר/פחות לפי ההקשר (דף לקוחות ציבורי מול פנימי); הלקוח צריך עדיפות אמיתית.
- פרטים נשכחים, סביבות משתנות, ולא ניתן לשחזר PoC ממכונה שאופסה.
- כ-30% מזמן הבדיקה.

חלק ב' — תרחיש מהחיים האמיתי

“אותו ממצא, שני דוחות” 

סיימת בדיקה ומצאת SQLi קריטי בדף לקוחות. עליך להציג אותו ל**שני** קהלים: המנכ"ל (לא-טכני) וצוות הפיתוח.

המשימה: 1. כתוב **פסקת Executive Summary** למנכ"ל — סיכון עסקי בלבד, ללא ז'רגון. 2. כתוב את אותו ממצא **לצוות הפיתוח** — טכני, עם PoC ותיקון. 3. דרג את הממצא ב-CVSS ונמק. 4. מה היית עושה אם גילית שהחולשה **כבר נוצלה** ע"י תוקף אמיתי (יש ראיות לפריצה קודמת)?

פתרון מנחה

1. **למנכ"ל:** < נמצאה חולשה קריטית באתר הלקוחות המאפשרת לתוקף לגשת לכלל בסיס נתוני הלקוחות, כולל פרטי אשראי. הסיכון: חשיפת מידע, קנס רגולטורי (GDPR/PCI) ופגיעה במוניטין. נדרש תיקון מיידי.

2. לצוות הפיתוח:

```
## SQL Injection ב-/search?q= – Critical (CVSS 9.8)
PoC: q=' UNION SELECT username,password FROM users--
[צילום]. credentials-נשלפו כל ה
. בניינים WAF; ולידציה; Prepared Statements (PDO/ORM); תיקון
הפניות: OWASP A03:2021, CWE-89.
```

3. **CVSS: 9.8** — וקטור רשת (AV:N), ללא הרשאות (PR:N), השפעה מלאה על סודיות/שלמות/זמינות.

4. **אם נוצלה בפועל:** זהו **Incident** — עצור, **תעד את הראיות בקפדנות** (שרשרת ראיות), והודע **מיד** לאיש הקשר של הלקוח לפי ה-RoE (יש סעיף “מה עושים אם מוצאים פריצה פעילה”). לא ממשיכים כרגיל — עוברים לתגובה לאירוע.

 היכולת לספר את **אותו סיפור בשתי שפות** (עסקית וטכנית) היא מה שהופך בודק חדירה לאיש מקצוע שלקוחות חוזרים אליו.

סוף הקורס

השלמת את כל 16 המודולים! עכשיו: ➡ **מבחן מעשי מסכם · בנק שאלות · דוגמאות מהעולם**

⬅ **חזרה למודול · תרגילים מעשיים**